

File creation isn't enabled in this chat (turning on code execution in Settings allows downloadable files), so the complete document is below. Use the copy button on this message and save it as KHOJI_FIN04_Technical_Documentation.md .

KHOJI — Financial Crime & Insider Risk Intelligence Platform

Technical Project Documentation · HackMatrix 5.0 (PCCOE, Pune) · Problem Statement FIN-04

Field	Value
Document type	Technical design, implementation and evaluation plan
Status	Proposed design (pre-implementation). No experimental results exist yet. Every metric in this document is still to be measured.
Prototype scope	24-hour hackathon build by a 4-member team
Date	September 2026

Reading conventions

- **Assumption:** a premise the design relies on.
- **Requires Validation:** a claim that must be verified experimentally.
- **Open Technical Decision:** a design detail that is not yet fixed.
- *Not specified in the provided material: information we do not have.*
- Numbers such as “3 branches” or “ $k \leq 8$ ” are **proposed configuration values**, not results.

Table of Contents

1. Executive Summary
2. Problem Statement
3. Existing Approaches
4. Proposed Solution
5. What Exactly Are We Building?
6. Objectives
7. System Requirements
8. System Architecture
9. Technology Stack
10. Technical Approach
11. Core Algorithm / Logic
12. Algorithms, Models and Techniques Used
13. End-to-End Workflow
14. Example System Execution
15. Novelty / Innovation
16. Existing Solutions vs Proposed Solution
17. Implementation Strategy
18. Data Flow
19. Feasibility
20. Risks and Mitigation
21. Failure Cases and Edge Cases

22. Security, Privacy and Reliability
23. Evaluation Strategy
24. Baseline Comparison
25. Experimental Setup and Success Criteria
26. Critical Review of the Proposed Design
27. Assumptions, Open Decisions and Validation Register
28. Demonstration Plan
29. Problem-Statement Traceability Matrix
30. Future Scope
31. Complete System Summary
32. One-Page Technical Snapshot
33. References

1. Executive Summary

The problem. In banks, suspicious money movements and unusual employee activity are monitored by different teams using different systems. That separation hides connections between insider privilege misuse and financial crime (HackMatrix FIN-04).

Insider-enabled frauds in India often follow one pattern: an employee who is technically *allowed* to change account state (registered mobile, beneficiaries, limits, account status) does so without the customer asking. Later transactions then pass every control, including OTP, because the control's inputs were already compromised.

- In one Mumbai case, a deceased customer's registered mobile and email were changed in July 2025 using a request form whose signatures did not match bank records. Two fixed deposits worth about 14.87 lakh were then closed early and moved out.
- In another case, a relationship manager redirected customers' mobile numbers to relatives, so real holders stopped receiving OTPs and alerts. She also enabled overdrafts on 40 accounts and closed fixed deposits of 31 customers.

Why it matters.

- RBI reported 23,953 fraud cases involving 36,014 crore in FY25.
- Transaction-monitoring alerts are widely reported to be 90–95% false positives.
- RBI requires banks to promptly examine staff accountability in fraud cases.
- The burden of proving customer liability in unauthorised electronic transactions lies on the bank.

Proposed solution. KHOJI is an investigation platform. It puts employee actions, access rights, authorizations, account-state changes, control evaluations and money flows on one tamper-evident timeline. It detects the three patterns named in the PS (circular transfers, transaction splitting, profile mismatches) and connects them to employee activity through typed, evidence-backed links. Every alert gets an explainable risk level and a mandatory evidence panel.

Core technical idea. KHOJI treats the bank's controls as an **executable model** and stores account state as **versions**. That enables two mechanisms:

1. **Hollow Pass.** Detect controls that *passed* while relying on inputs set by an unverified employee action. Example: an OTP delivered to a number an employee changed without customer evidence.
2. **Remove.** Replay history with candidate employee actions removed. Classify each action as necessary, jointly necessary, contributory, concealing or irrelevant to the recorded money path, under the modelled controls.

What is being built. A synthetic bank environment with ground truth; an evidence store; detection, access-rights, integrity, connection and counterfactual engines; an investigator dashboard with case management and evidence export; and an evaluation runner.

Expected benefit (Requires Validation):

- faster reconstruction of insider-enabled incidents
- fewer false alerts on legitimate look-alike activity
- earlier visibility of accounts that are "primed" before any money moves

Main innovation. Control-integrity checking (Hollow Pass) plus set-based counterfactual replay over banking controls (Remove), evaluated on an open benchmark of attack scenarios and paired legitimate twins. Most building blocks (graphs, rules, anomaly detection, replay, case management) already exist. The contribution is the specific mechanisms and the evaluation design, not the use of AI.

2. Problem Statement

2.1 What Problem Are We Solving?

Official FIN-04 statement (summarised). Build an investigation platform linking employees, access rights, customers and transactions. It should surface unusual patterns (circular transfers, transaction splitting to avoid attention, profile mismatches) with explainable, evidence-backed alerts.

Expected outcomes:

- a money-flow graph and activity timeline
- explainable risk levels rather than a single score
- case assignment and evidence export
- testing on suspicious *and* legitimate scenarios for detection accuracy and false-positive rate
- a mandatory evidence/explanation panel on every alert

Aspect	Description
Current situation	Fraud operations, AML analysts, vigilance/internal audit and IT security each see their own data: transactions, alerts, core-banking audit trails, access logs, HR records
Main pain point	When money is lost through insider-enabled paths, controls often <i>passed</i> . Reconstructing how it happened needs manual cross-system investigation.
Technical problem	Fuse heterogeneous, imperfect event streams; separate <i>dependency</i> from <i>coincidence</i> ; distinguish suspicious patterns from legitimate look-alikes; quantify uncertainty
Operational problem	Discovery is often late. The Mumbai case surfaced through a complaint about unauthorised contact changes. The Haryana government-accounts fraud surfaced when a reconciliation showed a mismatch between the department's balance and the bank's records.
Who encounters it	Bank investigators, AML/fraud analysts, vigilance teams, compliance leadership, customers (especially dormant, elderly or deceased-account holders), and honest employees who may be wrongly suspected
Where it occurs	Branch operations (contact changes, reactivations, overrides, account opening) and digital channels (beneficiary addition, transfers, FD closure)
Why it exists	(a) Controls validate <i>possession</i> of a factor, not the <i>legitimacy of how it was bound</i> . (b) Insiders use permissions they legitimately hold. © Evidence sits in separate systems. (d) Legitimate activity produces the same transaction shapes as crime.

Refined problem statement. Given imperfect logs of employee actions, authorizations, account-state changes, control evaluations and transactions, determine:

1. which money movements form suspicious patterns *not explained* by legitimate business context;
2. which employee actions those movements operationally depended on, and whether controls passed on compromised inputs;
3. how confident that determination is.

Present all of it as reviewable evidence without asserting intent.

2.2 Why Does This Problem Matter?

Aspect	Evidence	Relevance
Scale	23,953 cases, 36,014 crore in FY25. Private banks had 59.4% of cases; public-sector banks 71.3% of the amount. RBI data covers frauds of 1 lakh and above.	Material losses and operational load
Honest caveat on composition	Over 92% of FY25 fraud value related to advances (loans). Card/internet frauds led by count (13,516 cases).	Insider-enabled account frauds are an important <i>subset</i> , not the largest by value. Do not overclaim.
Mule ecosystem	I4C identified 26.5 lakh layer-1 mule accounts by end-2025. MHA directed all financial institutions to integrate with MuleHunter by December 2026.	National priority on account-level misuse
Insider involvement	~Half a dozen employees of a large private bank allegedly helped build a ~ 500 crore mule network (Alwar, 2025). In a separate case, one officer held both his own and his branch manager's password, bypassing maker-checker. Gurugram police reported arresting 23 bank employees in cyber-fraud cases in a single year.	Insiders are a recurring enabling factor
Alert noise	PwC reported 90–95% of transaction-monitoring alerts are false positives	Any new detection must control false positives
Accountability & liability	Staff-accountability examination is required. Customers get zero liability where the bank's own negligence or deficiency contributed.	Banks need <i>evidence of where the failure occurred</i>

2.3 Who Benefits?

Stakeholder	Current problem	How KHOJI helps	Benefit (Requires Validation)
Fraud / vigilance investigators	Manual stitching of audit logs, OTP logs, HR records	Automated chain: employee action state version control money	Less reconstruction effort; fewer sources to query manually
AML analysts	High false-positive volume	Explanation check suppresses patterns explained by pre-existing business evidence	Fewer alerts on payroll, sweeps, mutual trade
Compliance / risk leadership	Needs staff-accountability evidence and control improvements	Contribution graph, access-rights view, Repair table	Evidence-backed accountability reviews; control-gap insight
Customers (dormant, elderly, deceased accounts)	Exploited when alerts go to changed numbers	Hollow Pass + Reach flag exposure before money moves	Earlier intervention
Honest employees	Risk of blame when their credentials are misused	Credential ≠ person attribution; no-intent language	Reduced wrongful suspicion
Auditors / regulators	Need auditable trails	Hash-chained evidence, versioned alerts	Tamper-evident records
Law enforcement	Needs structured evidence	Exportable evidence pack	Faster handover

2.4 What Happens If the Problem Remains Unsolved?

Dimension	Consequence
-----------	-------------

Operational	Incidents are discovered via complaints or reconciliation after funds have moved
Technical	Controls keep deciding locally; nobody checks whether a pass was legitimate
Financial	Losses plus customer compensation where bank-side deficiency is established
Scaling	Adding more rules increases false-positive load (90–95% already reported)
Reliability	Manual reconstruction is slow and error-prone; evidence may be incomplete
User impact	Vulnerable customers stay exposed; honest staff may be wrongly suspected

2.5 Why Is This Problem Technically Interesting?

Challenge	Why it is hard	Where it appears
Heterogeneous temporal fusion	Different systems, clocks, granularities and delays	Ingestion, ordering, versioning
Dependency vs correlation	Time proximity is weak evidence; attribution needs dependency reasoning	Connection Engine, Remove
Overdetermination & cascades	Removing one event may not block a path when redundant enablers exist; removals change later events	Minimal-disabling-set replay
Legitimate look-alikes	Payroll $\approx$ splitting; treasury sweeps $\approx$ circular transfers; account recovery $\approx$ takeover	Explanation check, authorization grades
Extreme class imbalance	SAML-D has 9.5M transactions with only $\sim$ 0.1% suspicious	Evaluation design
Incomplete / out-of-order data	Missing MFA records, duplicates, clock skew	Evidence confidence, interval ordering
Identity ambiguity	Logs record credentials, not humans	Identity resolver
Adversarial behaviour	Insiders wait out cooldowns, split actions across colleagues, forge authorization	Threat model (§21)
Evaluation without real labels	Synthetic ground truth risks circularity	Blind scenario authoring, held-out families

2.6 Why Is Now a Good Time to Solve It?

Factor	Evidence
Regulatory push for analytics	RBI's 2024 directions require an early-warning framework with real-time monitoring, including digital transactions
National mule-account programme	MuleHunter integration mandated by December 2026
Widening legitimate cross-branch activity	RBI now requires KYC updation for reactivation at all branches, including non-home branches. Naive “non-home branch = suspicious” rules would misfire, so context-aware detection is needed.
Public benchmarks exist for the transaction layer	AMLworld: six synthetic datasets up to 180M transactions. SAML-D: 28 typologies (11 normal, 17 suspicious).
Mature open-source tooling	Python graph, analytics and web stacks make a 24h prototype feasible (<i>general engineering judgement, not a cited trend</i>)

3. Existing Approaches

3.1 How Is the Problem Currently Solved?

Layer	What it does	Examples
Preventive controls	Block unauthorised actions at execution time	OTP/MFA, device binding, limits, cooldowns, maker-checker, role permissions
Real-time enterprise fraud management	Score logins, beneficiary additions and transfers; block/hold/alert	Clari5 offers an Employee Fraud Management module, and its online-banking product monitors logins, beneficiary registrations and fund transfers
AML transaction monitoring	Rules/ML for laundering typologies; analyst review	Widely deployed; high false positives
Mule detection	ML on account behaviour	MuleHunter.AI uses supervised ensemble learning such as gradient boosting, positioned against high-false-positive rule systems. Live in 26 banks; banks are advised to use network analytics for mule networks.
National freezing network	Victim report ticket banks freeze funds in transit	CFCFRMS tracks stolen money bank to bank so it can be frozen. Over 11,158 crore saved across 3.28 million complaints up to 30 June 2026.
Commercial employee-fraud / link analysis	Correlate employee activity with transactions; relationship discovery	NICE Actimize: monitors transaction patterns, access logs and behavioural anomalies. Vyntra: links employee behaviour to transactions and control integrity (incl. four-eyes breaches). DataWalk: fuses transactions, KYC, employee access logs and HR into one knowledge graph. Quantexa: entity resolution and contextual monitoring to reduce false alerts.
Replay / backtesting	Test detection rules on history	CyberSource Decision Manager Replay: recomputes velocities and scores as of transaction time. Lithic: replays authorization rules against historical transactions. Flagright: runs rule changes on past data to project alert volumes.
Manual investigation	Vigilance/audit pull records by hand	Core-banking audit trail, OTP/SMS logs, HR records
Research	AML graph ML, insider-threat detection, provenance triage	See §3.2

3.2 Limitations of Existing Solutions

Approach	How it works	Strength	Limitation	Remaining gap
OTP / MFA	Verifies possession of the registered factor	Strong against outsiders without the factor	Does not verify how the factor was <i>bound</i> ; an insider-changed number passes	Channel-binding integrity
Maker-checker	Two-person rule	Effective against a lone careless actor	Defeated by collusion or credential sharing (PSB case)	Checker independence analysis

Cooldowns	Delay sensitive actions after changes (e.g. a 12-hour cooling period meant to give customers a window to report)	Buys time for customers	One bank's pause lifts automatically after 24h and can be shortened at a branch; another bank allows payments to existing payees during its cooldown	Waiting ≠ verification
Core-banking audit logs	Record every change	Complete record	Not connected to later transactions until investigated	Automated linkage
Real-time fraud engines (incl. employee modules)	Score events; flag anomalies	Mature, real-time	Public material does not describe control-integrity or counterfactual attribution (<i>internals unknown</i>)	Reconstruction of <i>how</i>
AML monitoring	Typology rules/ML	Regulatory coverage	High false positives	Context-aware explanation
MuleHunter	Account-behaviour ML	National scale	Focuses on mule accounts, not the insider enabling layer	Insider linkage
CFCFRMS	Post-report freezing	Recovers funds	Starts after a victim reports	Pre-loss exposure
Commercial link analysis / employee fraud	Graphs, entity resolution, employee monitoring	Proven at scale	Closed; public material doesn't document counterfactual replay over controls	Open, measurable method
Replay / backtesting	Change detection rule; keep history fixed	Safe rule tuning	Doesn't edit history or test <i>preventive</i> controls	Counterfactual over history and controls
Academic AML graph ML	GNN/GBT on transaction graphs; AMLworld baselines reach F1 up to ~60%	Strong transaction-pattern research	Transactions only; no employee/access layer	Joint modelling
Insider-threat research (CERT)	Behavioural anomaly on synthetic employee logs (1,000 employees, 18 months)	Canonical benchmark	Static, limited diversity, no money flows	Joint benchmark
Security provenance (NoDoze etc.)	Dependency graph per alert; rarity scoring; reported 86% false-alarm reduction	Proven triage concept	Operating-system events; scores rather than re-executing controls	Banking-control provenance

3.3 Why Are Existing Solutions Insufficient?

Existing systems are good at **flagging** suspicious transactions, accounts and employee behaviour. The unresolved gap, as far as the public material we reviewed shows, is **investigator-grade reconstruction**:

1. Did each control that passed rely on customer-verified inputs?
2. Which recorded employee actions was the money movement *operationally dependent* on, including redundant and cascading cases?
3. Which other accounts are in the same pre-loss state?
4. How confident is this, and what evidence is missing?
5. Can this be measured on an open benchmark that includes legitimate look-alikes?

Assumption: *Proprietary vendor systems may contain capabilities not described publicly. Our gap statement is limited to publicly documented material.*

4. Proposed Solution

4.1 Solution Overview

KHOJI puts everything that happens in a bank — employee actions, customer authorizations, account changes, control checks and money transfers — on **one timeline**.

When money moves in a suspicious pattern (a loop, a split, or activity that doesn't fit the customer), KHOJI checks whether legitimate business evidence explains it. If not, it looks for **connections** to employee activity.

It then answers three questions:

- **Remove:** "What did this depend on?" Delete an employee action from history and see whether the money could still have moved.
- **Reach:** "Where else could this happen right now?" Find accounts in the same dangerous state.
- **Repair** (*optional*): "Which single control change would have stopped it, and at what cost to genuine customers?"

It reports the verdict that ties everything together: whether any control **passed for the wrong reason** (Hollow Pass).

Every alert has a risk level with reasons and an evidence panel. Investigators can assign, decide and export cases. KHOJI never asserts intent; it outputs "inconclusive" when evidence is insufficient.

4.2 Proposed Solution in Technical Terms

Inputs (event types):

Event type	Key attributes
EmployeeAction	credential, session, device, terminal, target account, action type, status (executed / denied), timestamp, source sequence
AuthorizationArtifact	type (ticket, V-CIP, biometric, form), created_by, created_at, verified_by, customer channel
StateWrite	account, state variable (status, limit, beneficiary, mobile, email, device binding, profile fields), old new value
Approval	maker, checker, latency, terminal
MFAEvent	challenge id, destination channel version, result
ControlEvaluation	control id, inputs (version refs), outcome
Transaction	type, source, destination, amount, outcome, consumed state versions
Notification	channel version, delivered flag
HR / IAM	roles, permissions, assignments, delegations, overrides, permission changes, shifts, leave, attendance

Representation:

- append-only event log (hash-chained)
- versioned state tables
- in-memory temporal property graph (money flows + dependencies)
- executable control model Γ (policy-as-code)

Processing:

1. validation, deduplication, interval ordering
2. state versioning
3. pattern detection
4. explanation check

5. authorization grading and taint
6. access-rights signals
7. connection building
8. provenance collection
9. counterfactual replay
10. evidence confidence
11. triage

Outputs:

- versioned alerts with level + reasons
- evidence panel
- contribution graph with dependency roles
- Remove results + replay coverage
- Reach exposure list
- Repair table (optional)
- cases and hashed evidence packs

Feedback loops:

- **Investigator decisions:** “mark legitimate” creates a *scoped, expiring* suppression with a reason; confirmed links are logged.
- **Late-arriving data:** re-evaluates affected alerts, with an audit trail of upgrades and downgrades.
- **Baselines:** updated on a rolling window.

Validation mechanisms:

- expected-evidence contracts per event type
- replay coverage κ
- dual-order replay under timestamp ambiguity
- hash-chain verification on export
- single-source cap (no HIGH alert on a single unverified critical link)

5. What Exactly Are We Building?

5.1 Core Prototype (proves the central idea)

Component	Purpose	Claim it proves
Synthetic bank simulator + scenario library + ground truth	Joint employee/state/money data with labels	Testability, including false-positive rate (PS outcome 4)
Evidence store (hash-chained) + versioned state	Tamper-evident timeline; dependency linking	Evidence integrity; PS outcome 1
Pattern engine (circular transfers, splitting, profile mismatch) + explanation checker	Detect PS-named patterns; suppress explained ones	PS core requirement
Access-Rights & Privilege-Misuse module	Permissions, assignments, 10 misuse signals	“Access rights”, “insider privilege misuse”
Authorization grader + integrity engine (Hollow Pass)	Detect controls passing on compromised inputs	Core innovation 1
Connection Engine	Typed money employee links	“Connected anomalies”
Counterfactual engine: Remove (+ Reach)	Necessity classification; exposure scan	Core innovation 2
Evidence confidence + triage decision table	Explainable levels; INCONCLUSIVE	PS outcome 2

Dashboard: money-flow graph, timeline, evidence panel, access-rights panel	Investigator view	PS outcomes 1, 5
Case management + evidence export	Workflow	PS outcome 3
Evaluation runner (accuracy, FPR, ablation)	Proof	PS outcome 4

5.2 Supporting Features

- Collusion analysis (pair lift, checker independence)
- Identity/attribution panel
- Legitimate-twin comparison (“divergence point”)
- Liability-oriented export template
- **Repair** (4 candidate controls, single-change only; built only if time permits)

5.3 Future Extensions (outside prototype scope)

- Integration with real core-banking audit trails, MFA/SMS gateways, HR/IAM
- Streaming ingestion at production scale
- Cross-bank analysis
- Goods-movement/GST data for trade verification
- Learned triage ranking on real dispositions
- Richer control models

5.4 Explicitly Excluded (and why)

Excluded	Reason
Graph neural networks	No real labels; simulator labels would make them look artificially good; weaker explainability
LLM-based decisions	Unverifiable. An LLM may <i>narrate</i> evidence IDs at most (optional).
Blockchain	A SHA-256 hash chain gives tamper-evidence for this scope
Kafka / Neo4j / microservices	Setup risk with no prototype benefit
Chatbot, mobile app, real bank integrations	No contribution to the PS outcomes

6. Objectives

ID	Objective	Description	How it will be measured
O1	Unified evidence timeline	Link employees, access rights, customers, authorizations, state changes, controls and transactions	Every alert shows all layers; share of alerts with complete cross-layer links
O2	Detect PS-named patterns	Circular transfers, splitting, profile mismatch, both standalone and insider-connected	Detection accuracy (precision / recall / F1) per pattern and variant
O3	Control false positives on legitimate look-alikes	Suppress explained patterns and authorized actions	False-positive rate on legitimate twins and on all legitimate scenarios
O4	Detect insider privilege misuse	Misuse of <i>valid</i> access (P1–P10)	Precision of misuse signals vs ground truth

O5	Establish evidence-backed connections	Typed money employee links	Connection accuracy (type and credential) vs ground truth
O6	Classify operational dependency	Remove labels	Label accuracy on simple, overdetermined and cascade scenarios
O7	Detect hollow controls	Flag passes on tainted inputs	Hollow-flag precision/recall vs ground truth; ablation effect on twin FPR
O8	Surface pre-loss exposure	Reach finds primed accounts	Exposure recall on hidden primed accounts
O9	Explainable, uncertainty-aware alerts	Levels + reasons + evidence panel; INCONCLUSIVE when needed	Evidence completeness; abstention correctness on data-gap scenarios
O10	Investigator workflow	Assign decide export with integrity	End-to-end case completion in demo; export hash verification

Targets for all objectives: *to be established experimentally.*

7. System Requirements

7.1 Functional Requirements

ID	Requirement	PS link
FR1	Ingest and validate all event types in §4.2	Linking entities
FR2	Maintain versioned account, channel, beneficiary and profile state with writer references	Outcome 1
FR3	Record which state versions each transaction and control consumed	Outcome 1
FR4	Render a money-flow graph and a multi-lane activity timeline	Outcome 1
FR5	Detect time-respecting circular transfers	Named pattern
FR6	Detect transaction splitting against configured thresholds	Named pattern
FR7	Detect profile mismatches	Named pattern
FR8	Check each pattern for pre-dated, independent business explanation	False positives
FR9	Grade authorization of every state write (A-E, X, U)	Privilege misuse
FR10	Compute privilege-misuse signals P1-P10 per credential	Access rights
FR11	Propagate taint and flag Hollow Passes	Explainability
FR12	Build typed connections (5 types) with strength	Connected anomalies
FR13	Run Remove replay and output dependency roles + coverage	Evidence-backed
FR14	Run Reach scan from a confirmed path template	Surfacing patterns
FR15	Compute evidence confidence and missing-evidence lists	Evidence-backed
FR16	Assign explainable risk levels via a decision table	Outcome 2

FR17	Show a mandatory evidence panel on every alert, incl. INFO/DATA-GAP	Outcome 5
FR18	Support case assignment, status workflow and decisions	Outcome 3
FR19	Export evidence packs (PDF + JSON manifest with hashes)	Outcome 3
FR20	Evaluate detection accuracy and FPR on suspicious and legitimate scenarios; run ablations	Outcome 4
FR21 (optional)	Repair: evaluate 4 candidate controls for block/friction	Differentiator

7.2 Non-Functional Requirements

Category	Requirement	How verified
Explainability	Every alert level traceable to rules and evidence rows	Review of all alerts in test runs
Evidence integrity	Tampering with stored events is detectable	Hash verification test with deliberate modification
Determinism	Same seed same data, alerts and metrics	Repeated runs comparison
Performance	Replay and alert rendering interactive enough for a live demo	Measure; no target specified
Reliability	Graceful handling of missing, duplicate and out-of-order data	Imperfection-injection tests
Privacy	Synthetic data only in prototype; no real PII	Data review
Security	Role-based access for investigator/supervisor (prototype-level)	Access tests
Fairness to employees	No intent language; credential-level attribution	UI copy review
Usability	Reviewer can answer “what, how, who, how sure” from the alert screen	Informal walkthrough (optional small user test)
Maintainability	Control model and scenarios in declarative YAML	Code review
Scalability	Prototype scale only; production path documented	\$19.6

8. System Architecture

8.1 Architecture Diagram

```
flowchart TB
  subgraph S["1 · Data Sources"]
    SIM["Synthetic Bank Simulator<br/>+ Scenario Library + Ground Truth"]
  end
  subgraph D["2 · Data Layer"]
    ING["Ingestion & Validation<br/>dedup · ordering · completeness"]
    EVS["Evidence Store<br/>append-only · hash-chained"]
    VST["Versioned State Store<br/>account · channel · beneficiary · profile"]
    CTL["Control Model<br/>bank rules as code"]
  end
  subgraph A["3 · Analysis Layer"]
```

```

PAT["Pattern Engine<br/>cycles · splitting · profile mismatch"]
EXP["Explanation Checker"]
AUT["Authorization Grader"]
IDR["Identity Resolver"]
ACC["Access-Rights &<br/>Privilege-Misuse Module"]
INT["Integrity Engine<br/>Hollow Pass"]
CON["Connection Engine"]
PRV["Provenance Collector"]
CFE["Counterfactual Replay Engine<br/>Remove · Reach · Repair"]
EVC["Evidence Confidence"]
TRI["Triage Decision Table"]
end
subgraph P["4 · Presentation Layer"]
  API["FastAPI + WebSocket"]
  UI["Investigator Dashboard"]
  CASE["Case Management<br/>+ Evidence Export"]
end
EVAL["Evaluation Runner<br/>metrics + ablation"]

SIM --> ING
ING --> EVS
ING --> VST
EVS --> PAT
VST --> PAT
PAT --> EXP
EVS --> AUT
AUT --> INT
VST --> INT
CTL --> INT
EVS --> IDR
IDR --> ACC
AUT --> ACC
EXP --> CON
ACC --> CON
INT --> CON
CON --> PRV
PRV --> CFE
CTL --> CFE
VST --> CFE
CFE --> EVC
CON --> EVC
EVC --> TRI
TRI --> API
API --> UI
UI --> CASE
CASE --> EVS
TRI --> EVAL
SIM -. ground truth .-> EVAL

```

8.2 Component Specifications — Data Layer

Component	Purpose	Input	Processing	Output	Interacts with	Technology	Why selected
Simulator + scenario	Generate realistic	Config (branches,	Process models for	Event stream +	Ingestion, Evaluation	Python	No public joint dataset

library	bank activity with labels	employees, customers, days), scenario YAML, seeds	normal ops; scenario injection; imperfection injection	ground-truth YAML			exists
Ingestion & validation	Clean and order events	Raw events	Schema checks, dedup by (source, seq), skew-bounded intervals, completeness contracts	Validated events, gap records	Evidence store, state store	Python	Simple, testable
Evidence store	Tamper-evident source of truth	Validated events, case actions	Append; SHA-256 chain $h_i = H(h_{i-1} e_i)$	Immutable log	All analysis components, export	DuckDB + hashlib	Fast analytics, zero setup
Versioned state store	Know state “as of” any time and who set it	StateWrites	Close previous version, open new one with writer ref	Version tables	Pattern, Integrity, Counterfactual	DuckDB tables	Enables replay and dependency links
Control model	Executable bank rules	YAML predicates	Evaluate predicates on (transaction, state)	PASS/FAIL per control	Integrity, Counterfactual	Python + YAML	Readable, replayable, explainable

8.3 Component Specifications — Analysis Layer

Component	Purpose	Input	Processing	Output	Technology	Why selected
Pattern engine	Detect PS-named patterns	Transfers, profiles	Time-respecting cycles; sliding-window splitting; Isolation Forest + rules	Pattern candidates + features	NetworkX, pandas, scikit-learn	Definitional typologies; explainable features
Explanation checker	Separate business from crime	Candidates, mandates, group codes, history	Checks for pre-dated, independent evidence	Explained / partial / unexplained + reasons	Python	Main false-positive control
Authorization grader	Grade each state write	StateWrites, artifacts	Rule-based A-E, X, U	Grade per write	Python	Transparent, auditable
Identity resolver	Credential ≠ person	Sessions, devices, network, attendance, leave	Consistency checks	Attribution consistency	Python	Protects innocent staff
Access-Rights module	Privilege misuse	Roles, permissions, assignments, delegations,	Signals P1-P10; “who else could have done this”	Signal list per credential	Python	PS “access rights” requirement

		overrides, actions				
Integrity engine	Hollow Pass	Grades, versions, control evaluations	Taint propagation into control inputs	Hollow flags	Python	Core innovation
Connection Engine	Money employee links	Candidates, versions, actions, approvals, devices	Typed linking (5 types)	Connections + strength	NetworkX	PS “connected anomalies”
Provenance collector	Candidate enablers	Target transaction	Backward dependency traversal within lookback	Candidate set C	NetworkX	Bounds replay
Counterfactual engine	Remove / Reach / Repair	C, history, Γ	replay(history_edit, control_config)	Roles, coverage, exposure, block/friction	Python	One engine, three questions
Evidence confidence	Quantify certainty	Evidence items	Completeness, corroboration, integrity, weakest-link	Confidence level + gaps	Python	Never invent evidence
Triage	Explainable levels	All above	Ordered decision table	Level + reasons	Python	PS: no opaque score

8.4 Component Specifications — Presentation Layer

Component	Purpose	Technology	Why selected
API	Serve alerts, cases, replay results; stream the live timeline	FastAPI + WebSocket	Lightweight; supports live demo
Dashboard	Graph, timeline, alert card, evidence, access-rights, Remove/Reach/Repair panels	React + Cytoscape.js + timeline component (dark theme)	Graph + timeline visualisation
Case management & export	Assign, decide, export	FastAPI + DuckDB; PDF + JSON manifest	PS outcome 3
Evaluation runner	Metrics, ablation	Python (pytest-style)	Reproducible proof

Open Technical Decision: exact React timeline library and PDF generation library.

9. Technology Stack

Layer	Technology	Purpose	Why selected
Simulation	Python, NumPy, YAML	Scenario generation, seeded randomness	Fast to write; declarative scenarios

Storage	DuckDB	Event log, versions, cases	Embedded, analytical, zero operations
Integrity	SHA-256 (hashlib)	Hash chain, export manifest	Standard, sufficient for tamper-evidence
Graph	NetworkX	Money flows, dependencies, traversal	Adequate at prototype scale; no database operations
Rules / control model	Python + YAML	Predicates, decision table	Readable and replayable
ML	scikit-learn (Isolation Forest); smoothed frequency baselines	Profile mismatch; behavioural rarity	Explainable, justified by the problem
Backend	FastAPI + WebSocket	API, live streaming	Simple, async
Frontend	React, Cytoscape.js, timeline component	Dashboard	Graph + timeline visualisation
Export	PDF + JSON	Evidence packs	Reviewer-friendly + machine-verifiable
Evaluation	Python test runner	Metrics, ablation	Reproducible
Deployment	Local machine(s)	Demo	No cloud dependency during judging

Rejected technologies

Technology	Why rejected
GNN / temporal GNN	No real labels; circular on simulator; weak explainability; build time
LLM for scoring/decisions	Unverifiable; hallucination risk
Neo4j	Setup risk; NetworkX suffices at this scale
Kafka / microservices	No prototype benefit
Blockchain	Hash chain gives tamper-evidence

10. Technical Approach

Stage	Input	Processing	Algorithm	Data structures	Constraints	Output	Compute notes
S1 Generate	Config, seeds, scenario YAML	Simulate normal ops, inject scenarios and imperfections	Process models	Event lists	Reproducible seeds	Events + ground truth	Linear in events
S2 Validate & order	Raw events	Dedup, schema, skew intervals, completeness	Interval ordering	Hash maps, sorted lists	Never drop conflicting records silently	Validated events + gap log	$O(n \log n)$ sort
S3 Version	StateWrites	Close/open versions	Temporal versioning	Per-account sorted version lists	Every version has a writer	Version tables	$O(\log V)$ as-of lookup

S4 Detect	Transfers, profiles	Patterns	Cycle enumeration, sliding window, Isolation Forest	Multigraph, deque, feature vectors	Length $\leq L$, window W	Candidates	See §11.6
S5 Explain	Candidates + business records	Pre-dated evidence check	Rule checks	Hash maps	Explanation must pre-date and be independent	Explanation status	Linear
S6 Grade & taint	StateWrites, artifacts, controls	Grades A–E/X/U; taint; Hollow Pass	Rules + propagation	Version flags	Sanitization only via clean channel	Hollow flags	Linear in writes
S7 Access rights	Actions, permissions, assignments	P1–P10	Rules + pair lift + peer rarity	Counters	Peer baselines per role	Signals	Linear
S8 Connect & collect	Candidates, versions	Typed links; candidate enablers	Backward traversal	Dependency graph	No time-only links; lookback Λ	Connections, C	Bounded by Λ
S9 Counterfactual	C, H, Γ	Remove, Reach, (Repair)	Minimal disabling sets; precondition scan	Subset lattice	$k \leq k_{\max}$; coverage κ	Roles, exposure	$\leq 2^k$ replays
S10 Confidence & triage	All results	Weakest-link confidence; decision table	Ordered rules	—	Single-source cap	Alert + evidence panel	Constant per alert

11. Core Algorithm / Logic

11.1 Input Representation

- **Event** $e = (\text{id}, \text{type}, \text{cred}, \text{session}, \text{device}, \text{target}, t_{\text{claim}}, t_{\text{ingest}}, \text{source}, \text{seq}, \text{payload}, \text{auth_ref})$
- **State variables** per account: `status`, `limit`, `beneficiaries`, `mobile`, `email`, `device_binding`, `profile_fields`
- **Version** $v = (\text{account}, \text{variable}, \text{value}, \text{valid_from}, \text{valid_to}, \text{writer_event})$
- **Transaction** $T = (\text{id}, \text{type}, \text{src}, \text{dst}, \text{amount}, t, \text{consumed_versions}, \text{outcome})$
- **Control model** $\Gamma = \{\gamma_c\}$ where $\gamma_c(T, S_t) \in \{\text{PASS}, \text{FAIL}\}$, and S_t is state as of time t
- **History** H = validated event sequence. State is a fold over H .
- **Authorization grade** $g(e) \in \{A, B, C, D, E, X, U\}$, where U = authorization source unavailable (distinct from E = source available but no artifact)
- **Taint** $\tau(v) \in \{0, 1\}$
- **Timestamps as intervals** $[t_{\text{claim}} - \epsilon_{\text{source}}, t_{\text{claim}} + \epsilon_{\text{source}}]$

Example control predicate (new-beneficiary transfer):

```
PASS iff status = ACTIVE
beneficiary beneficiaries(S_t) t – added_at(beneficiary) ≥ cooling
amount ≤ limit_remaining(S_t)
OTP delivered to mobile(S_t) and verified
```

11.2 Core Data Structures

Structure	Use
Append-only table + hash chain	Evidence log
Per-(account, variable) sorted version list	“As-of” lookup; replay
Directed multigraph (accounts, timed transfers)	Cycles, fan-in/out, pass-through
Dependency DAG (events versions transactions/controls)	Provenance, connections
Sliding-window dequeues per source/destination	Splitting detection
Feature matrices	Isolation Forest, baselines
Counters (role × action × account type × hour)	Rarity baselines
Maker-checker pair counts	Pair lift
Subset lattice with superset pruning	Minimal disabling sets
Decision table (ordered rules)	Triage

11.3 Core Algorithms

Algorithm 1 — Authorization Grading, Taint and Hollow Pass

Input: state-writing event e ; artifacts; control evaluation c
Output: $g(e)$; $\tau(v)$; $hollow(c)$

GRADE(e):

1. if authorization source for e 's channel is unavailable: return U
2. art ← artifacts linked to e
3. if art is empty: return E
4. if any artifact created after $e.t$
or created by $e.actor$ as ticket-only
or customer deceased before $e.t$
or signature-mismatch flag
or artifact reused across accounts: return X
5. if some artifact is V-CIP / biometric-at-branch / long-standing bound app device
and that channel is itself untainted: return A
6. if in-person verification by a staff member $\neq e.actor$: return B
7. if customer document verified by $e.actor$: return C
8. return D

TAINT(v):

9. $\tau(v) \leftarrow \text{GRADE}(\text{writer}(v)) \in \{D, E, X\}$
10. if a later sanitizing event re-confirms v via an untainted customer channel: $\tau(v) \leftarrow 0$
11. if $\text{GRADE}(\text{writer}(v)) == U$: $\tau(v) \leftarrow \text{UNKNOWN}$ (propagates to DATA_GAP, never to HIGH)

HOLLOW(c):

12. return $c.outcome == \text{PASS}$ and $\forall v \in \text{inputs}(c)$ with $\tau(v) == 1$

Algorithm 2 — Time-Respecting Circular Transfers

Input: transfer multigraph; window W (proposed 72h fast, 30d slow); max length L (proposed 6)
Output: cycles with features

1. on each new transfer $e_0 = (a \rightarrow b, t_0)$:
2. depth-first search from b over transfers e with
 $\text{time}(e) > \text{time}(\text{previous})$ and $\text{time}(e) \leq t_0 + W$, path length $\leq L$,
no repeated account
3. if the path returns to a : emit cycle C
4. features(C): close_time; return_ratio = amount(last) / amount(e_0);
passthrough(x) = out_x / in_x within Δ for intermediates;
account_age; relationship_age; recurrence; economic_outflow
5. pass C to ExplanationCheck and ConnectAnomalies

Algorithm 3 — Transaction Splitting

Input: transfers per source (or destination) in window W (proposed 24–72h);
threshold T ; band δ ; minimum count $n_{\min}$
Output: splitting candidates

1. $X = \{x \text{ in window} : (1 - \delta) \cdot T \leq \text{amount}(x) < T\}$
2. if $|X| \geq n_{\min}$ and $\sum \text{amount}(X) \geq T$:
3. features: $|X|$, mean proximity to T , $\sum T$, deviation from source baseline,
#beneficiaries, #new beneficiaries, inter-arrival times
4. emit candidate ExplanationCheck ConnectAnomalies

Open Technical Decision: values of T (which thresholds to model), δ and $n_{\min}$.

Algorithm 4 — Connection Engine

Input: money-side candidate M with accounts $\text{Acc}(M)$, transactions $\text{Tx}(M)$; lookback Λ
Output: connections $\{(\text{credential}, \text{type}, \text{strength}, \text{evidence})\}$

1. for T in $\text{Tx}(M)$, for v in consumed(T) (recursively via writers within Λ):
2. if writer(v) is an EmployeeAction: add (cred, STATE_DEPENDENCY, strongest)
3. for approvals on that writer: add (checker, APPROVAL, medium-strong)
4. for x in $\text{Acc}(M)$:
5. if opened/reactivated by an employee: add (cred, ONBOARDING, strong)
6. if profile fields edited by an employee within Λ : add (cred, PROFILE_EDIT, strong)
7. shared terminal/device/IP between employee actions and M 's accounts:
add (cred, INFRASTRUCTURE, medium, context-only)
8. NEVER add a connection from time proximity alone

Algorithm 5 — Remove (minimal-disabling-set replay with cascade)

Input: target transaction T^* ; history H ; control model Γ ; lookback Λ ; $k_{\max}$ (proposed 8)
Output: role(e) per candidate; disabling sets D ; coverage κ ; status

1. C = state-writing events in T^* 's dependency ancestry within Λ
2. if $|C| > k_{\max}$: keep top $k_{\max}$ by (dependency depth, grade severity, rarity);
status = PARTIAL
3. κ = $| \text{modelled controls applicable to } T^* | / | \text{controls applicable to } T^* |$
4. if $\kappa < \kappa_{\min}$: return INCONCLUSIVE ("control not modelled: ...")
5. orders = consistent orderings of $C \setminus \{T^*\}$ under timestamp intervals
6. for each order o in orders:
7. D_o
8. for $s = 1 \dots |C|$:
9. for $S \subseteq C$, $|S| = s$, with no $D' \subseteq D_o$ such that $D' \subseteq S$:

```

10. if  $\text{REPLAY}(H \setminus S, \Gamma, T^*, o) == \text{FAIL}$ :  $D_o \leftarrow D_o \cup \{S\}$ 
11. if the  $D_o$  differ across orders: return INCONCLUSIVE ("ordering ambiguity")
12. for  $e$  in  $C$ :
13. if  $\{e\} \subseteq D$ : NECESSARY
14. elif  $e \subseteq S$  for some  $S \in D$ ,  $|S| \geq 2$ : JOINTLY_NECESSARY
15. elif  $e$  writes only notification/detection inputs: CONCEALING
16. else: CONTRIBUTORY
17. events without a dependency edge to  $T^*$  are IRRELEVANT (never candidates)
18. return roles,  $D$ ,  $\kappa$ , status

```

```

REPLAY( $H'$ ,  $\Gamma$ ,  $T^*$ ,  $o$ ):
a. rebuild versions from  $H'$  (removed events' versions never exist)
b. for each recorded operation  $op$  in  $H'$  in order  $o$ , up to  $T^*$ :
c. evaluate applicable  $\gamma \in \Gamma$  on the rebuilt state
d. if any  $\gamma$  fails:  $op$  does NOT execute; drop  $op$ 's state effects (cascade)
e. return PASS if  $T^*$  executes, else FAIL

```

Semantics (stated explicitly in the UI).

- Replay holds **other actors' recorded behaviour fixed**; it does not invent alternative attacker actions.
- Therefore "NECESSARY" means: *the recorded path could not execute without this event under the modelled controls*. It does **not** mean causation in the statistical sense, and never intent.

Algorithm 6 — Reach (exposure scan)

```

Input: confirmed path template  $P = (p_1 \dots p_m)$ ,  $p_m$  = final transfer
      (e.g.  $p_1$  channel tainted;  $p_2$  beneficiary added via tainted channel;
       $p_3$  dormant/senior/high-balance;  $p_4$  no customer-origin artifact); current state
Output: exposed accounts ranked by exposure

```

```

1. for each account  $x$ :
2. if  $p_1 \dots p_{m-1}$  all hold and  $p_m$  does not: EXPOSED
   (exposure = available balance + limit headroom)
3. elif  $\geq m-2$  predicates hold: NEAR-EXPOSED (WATCH)
4. rank; attach the credentials that wrote the tainted versions

```

Algorithm 7 — Repair (scoped, optional)

```

Input: incident  $T^*$ ; candidate controls  $R = \{R_1 \dots R_4\}$ ; legitimate history  $B$ 
Output: per control:  $\text{blocks}(T^*) \subseteq \{Y, N\}$ ; friction on  $B$ 

```

```

1. for  $r$  in  $R$ :
2.  $\text{blocks} \leftarrow \text{REPLAY}(H, \Gamma \setminus \{r\}, T^*) == \text{FAIL}$ 
3.  $\text{friction} \leftarrow$  number of legitimate operations in  $B$  that REPLAY under  $\Gamma \setminus \{r\}$ 
   marks delayed/blocked, normalised per 10,000 operations
4. single-control evaluation only; no combination search in the prototype

```

Candidate controls:

- **R1**: remove contact-change rights on dormant/senior accounts from the Ops role
- **R2**: independent checker (different reporting line) for contact changes and limit overrides
- **R3**: call-back on the old number before cooldown expiry
- **R4**: 24h hold on new-beneficiary transfers above the cap after a limit raise

Algorithm 8 — Evidence Confidence

conf(link) from: completeness (expected items present), corroboration (# independent sources),
integrity (hash verified), temporal certainty (interval width)
level(link) {HIGH, MEDIUM, LOW}
conf(chain) = min over critical links (weakest link)
INSUFFICIENT if $\kappa < \kappa_{\min}$ or a critical link is missing
Single-source cap: no HIGH alert may rest on a single-source critical link

Algorithm 9 — Triage (first matching rule wins)

1. confidence INSUFFICIENT or ordering ambiguous DATA_GAP
2. pattern explained by pre-dated independent evidence
and no insider connection INFO
3. outcome BLOCKED and insider connection NEAR_MISS
4. COMPLETED connection {STATE_DEPENDENCY, APPROVAL}
grade {D, E, X} (hollow role == NECESSARY) conf $\geq$ MEDIUM
HIGH (insider-connected)
5. connection {ONBOARDING, PROFILE_EDIT} grade {D, E, X} HIGH (insider-connected, context)
6. unexplained pattern with red flags HIGH (AML)
7. unexplained pattern MEDIUM
8. privilege-misuse signals or tainted primed state, no money yet WATCH
9. apply single-source cap; attach reasons for the chosen rule

11.4 Decision Logic

Decision	Rule
Is a pattern “business”?	Only if explained by evidence that pre-dates it and comes from an independent, authorized source. Post-hoc or self-created explanations are graded X and <i>raise</i> risk.
Is there a connection?	Only via typed links (§Alg. 4). Strength order: state dependency > profile edit $\approx$ onboarding > approval > infrastructure (context only).
Is an employee action relevant?	Only if in the dependency ancestry. Remove decides necessary / jointly necessary / contributory / concealing.
Did a control work?	PASS + untainted inputs = genuine pass. PASS + tainted inputs = Hollow. FAIL = control held (near-miss if insider-connected).
Who is shown?	Credentials with attribution consistency. Never “who is guilty”.
When to abstain?	Insufficient evidence, low coverage, or order-dependent conclusions INCONCLUSIVE / DATA_GAP

Collusion statistic (pair lift):

$$\text{lift}(a, b) = n(a, b) \cdot N / (n(a, \cdot) \cdot n(\cdot, b))$$

where $n(a, b)$ counts changes made by a and checked by b , and N is the total checked changes. It is combined with approval latency, same terminal and same reporting line.

11.5 Constraints

1. No links from time proximity alone.
2. Explanations must pre-date the pattern and be independent.
3. $k \leq k_{\max}$ candidates per replay (proposed 8); otherwise PARTIAL/INCONCLUSIVE.

4. Replay coverage $\kappa \geq \kappa_{\min}$. **Open Technical Decision:** $\kappa_{\min}$ value, and how to compute the denominator outside simulation.
5. Other actors held fixed in replay.
6. Single-source cap on HIGH.
7. No intent claims.
8. Repair is single-control only in the prototype.

11.6 Complexity

Component	Cost	Notes
Ingestion / versioning	$O(n \log n)$ sort; $O(\log V)$ as-of lookup	n events, V versions per variable
Cycle detection	Bounded DFS per new transfer; worst case exponential in L	Pruned by time window and $L \leq 6$
Splitting	Amortised $O(1)$ per transfer with deques	Per source/destination
Isolation Forest	Train $O(t \cdot \psi \cdot \log \psi)$; score $O(t \cdot \log \psi)$ per account	t trees, subsample ψ (standard properties)
Connection	$O(\text{ancestry size within } \Lambda)$ per transaction	Bounded by lookback
Remove	$\leq 2^k \times \text{replays} \times O(m)$ per replay	$k \leq 8 \leq 256$ replays; superset pruning reduces this
Reach	$O(A \cdot m)$	A accounts, m predicates
Repair	$O(R \cdot B)$	4 controls $\times$ legitimate history

Requires Validation: wall-clock latency of Remove per alert at prototype scale.

12. Algorithms, Models and Techniques Used

T1 — Versioned temporal state

Aspect	Detail
What	Each state change creates an immutable version with validity interval and writer
Role	Foundation for dependency links, Hollow Pass, replay
Why required	Time windows over-link busy branches and miss slow attacks (e.g. a July change used later)
Why over alternatives	Timestamp correlation cannot tell which state a transaction actually used
I/O	StateWrites version tables; as-of queries
Advantages	Exact dependency; replayable
Limitations	Requires transactions/controls to log consumed state (Assumption for production)
Location	Data layer; used by Pattern, Integrity, Counterfactual

T2 — Time-respecting cycle enumeration

Aspect	Detail
What	Bounded DFS finding loops whose hops are time-ordered within a window
Role	Circular-transfer detection (PS pattern)

Why required	Named by the PS
Why over alternatives	Standard, explainable. The Graph Feature Preprocessor work uses time windows and cycle-length constraints for similar features.
I/O	Transfer multigraph cycles + features
Advantages	Exact, explainable evidence edges
Limitations	Exponential worst case; needs L and W bounds
Location	Pattern engine

T3 — Sliding-window splitting detector

Aspect	Detail
What	Clusters of just-below-threshold amounts summing above the threshold
Role	Transaction-splitting detection
Why required	Named by the PS
Why over alternatives	Direct operationalisation; explainable
I/O	Transfers candidates
Advantages	Simple, fast
Limitations	Threshold choice; legitimate regular payments can resemble it (handled by explanation check)
Location	Pattern engine

T4 — Isolation Forest (profile mismatch)

Aspect	Detail
What	Unsupervised anomaly detector isolating outliers with random partitioning trees
Role	Flags activity inconsistent with declared profile
Why required	PS names profile mismatch; no labelled real data
Why over alternatives	Needs no labels; cheap. Autoencoders add complexity without clear benefit at this scale.
I/O	Features (flow vs income band, counterparty diversity, pass-through, history break) anomaly score
Advantages	Fast; feature-level explanations possible
Limitations	Sensitive to feature design and contamination parameter (Open Technical Decision)
Location	Pattern engine

T5 — Smoothed frequency baselines (behavioural rarity)

Aspect	Detail
What	Role × action × account-type × hour frequencies with smoothing
Role	“Unusual for this role” signals (P3, P9)

Why required	Global thresholds drive false positives
Why over alternatives	Explainable, in the spirit of rarity-based scoring (NoDoze)
I/O	Action history rarity score
Advantages	Transparent
Limitations	Cold start for new roles; drift
Location	Access-Rights module

T6 — Rule-based authorization grading

Aspect	Detail
What	Grades A–E, X, U from artifacts and consistency checks
Role	Separates customer-requested from employee-only changes
Why required	Twins differ <i>only</i> in authorization
Why over alternatives	Deterministic, auditable; ML would need labels
I/O	StateWrite + artifacts grade
Advantages	Explainable
Limitations	Cannot detect a perfect forgery; detects inconsistencies only
Location	Authorization grader

T7 — Taint propagation (Hollow Pass)

Aspect	Detail
What	Marks versions written without customer-verified authorization; propagates to control inputs
Role	Detects controls passing for the wrong reason
Why required	OTP success on an insider-changed number looks legitimate otherwise
Why over alternatives	Taint tracking is a known information-flow technique; its application to control inputs is our design
I/O	Grades + versions + control evaluations hollow flags
Advantages	Directly explainable
Limitations	Depends on grading quality and sanitization rules (Open Technical Decision)
Location	Integrity engine

T8 — Typed backward dependency traversal (Connection Engine)

Aspect	Detail
What	Walks from transactions/accounts to employee writers, approvers, onboarders, profile editors, infrastructure
Role	Establishes “connected anomalies”
Why required	PS core requirement

Why over alternatives	Link analysis by shared attributes alone over-links. Typed dependencies carry strength.
I/O	Candidate connections
Advantages	Explainable, graded strength
Limitations	Infrastructure links are context only
Location	Connection Engine

T9 — Minimal-disabling-set replay (Remove)

Aspect	Detail
What	Enumerates subsets of candidate events whose removal blocks the recorded path
Role	Necessity classification
Why required	Single-event but-for misclassifies redundant enablers
Why over alternatives	Detection-rule backtesting changes the rule, not history. Formal actual-causality frameworks are richer but heavier; we use a weaker, operational notion on purpose.
I/O	C, H, Γ roles, D, κ
Advantages	Handles redundancy and cascades; auditable
Limitations	Exponential in k; depends on control-model fidelity
Location	Counterfactual engine

T10 — Precondition-template matching (Reach)

Aspect	Detail
What	Finds accounts satisfying all but the final step of a confirmed path
Role	Pre-loss exposure
Why required	Stop the next loss, not just explain the last
Why over alternatives	Link analysis finds <i>related</i> accounts; Reach finds accounts in the same <i>state</i>
I/O	Template + current state ranked accounts
Advantages	Actionable, explainable
Limitations	Only as good as the template
Location	Counterfactual engine

T11 — Single-control counterfactual (Repair)

Aspect	Detail
What	Adds one candidate control to Γ and replays incident + legitimate history
Role	Control recommendation with friction
Why required	Optional differentiator
Why over alternatives	Rule backtesting tools test detection rules; this tests preventive controls

I/O	R, H, B block/friction table
Advantages	Actionable
Limitations	Simulated friction only
Location	Counterfactual engine

T12 — Pair-lift statistics (collusion)

Aspect	Detail
What	Observed vs expected maker-checker pairing
Role	Signal P5
Why required	Two-person rules can be defeated jointly
Why over alternatives	Simple and explainable. Process-mining audits already look for segregation-of-duties violations and people involved in multiple violations.
I/O	Approval counts lift
Advantages	Cheap
Limitations	Small-sample noise
Location	Access-Rights module

T13 — Expected-evidence contracts + weakest-link confidence

Aspect	Detail
What	Declares required evidence per event type; chain confidence = weakest critical link
Role	Honest uncertainty
Why required	Real logs are imperfect; the system must never invent evidence
Why over alternatives	Probabilistic fusion would imply calibration we cannot validate
I/O	Evidence items level + gaps
Advantages	Conservative, explainable
Limitations	Coarse levels
Location	Evidence confidence

T14 — Decision-table triage

Aspect	Detail
What	Ordered rules mapping evidence to levels
Role	Explainable risk levels (PS outcome 2)
Why required	PS forbids an opaque single score
Why over alternatives	Weighted sums hide reasons
I/O	All results level + reasons
Advantages	Auditable

Limitations	Manual rule design; brittle if over-extended
Location	Triage

T15 — SHA-256 hash chain

Aspect	Detail
What	Each record's hash includes the previous hash
Role	Tamper-evidence
Why required	Evidence export must be verifiable
Why over alternatives	Blockchain adds no benefit here
I/O	Records chain; verification
Advantages	Simple
Limitations	Someone with write access can recompute the chain unless the head hash is anchored externally (see §26)
Location	Evidence store, export

T16 — Interval-based temporal ordering

Aspect	Detail
What	Per-source skew bounds; dependency and sequence ordering preferred over wall clock
Role	Robust ordering
Why required	Clock drift, delays, out-of-order logs
Why over alternatives	Point timestamps create false certainty
I/O	Events ordered sets + ambiguity flags
Advantages	Enables dual-order replay
Limitations	Skew bounds must be configured per source (Open Technical Decision)
Location	Ingestion, Counterfactual

13. End-to-End Workflow

1. The simulator (or, in future, real sources) emits events.
2. Ingestion validates the schema, deduplicates by (source, sequence), assigns time intervals and checks expected-evidence contracts. Gaps are logged, not filled.
3. Events are appended to the hash-chained evidence store. State writes create new versions.
4. The pattern engine updates cycles, splitting windows and profile features incrementally.
5. The explanation checker labels each candidate explained / partial / unexplained, with reasons.
6. The authorization grader grades each state write. The integrity engine propagates taint and flags Hollow Passes.
7. The identity resolver scores attribution consistency. The access-rights module computes P1–P10 and “who else could have done this”.
8. The Connection Engine links money-side candidates to employee-side activity with typed strength.
9. The provenance collector gathers candidate enablers for each connected transaction.
10. The counterfactual engine runs Remove (roles, coverage) and Reach (exposure). Repair runs if enabled.

- 11. Evidence confidence computes the weakest-link level and missing items.
- 12. Triage assigns a level with reasons. The alert (versioned) is created with a mandatory evidence panel.
- 13. The investigator opens the alert: graph, timeline, Control Path, access rights, Remove toggle, Reach list, legitimate comparison.
- 14. The investigator assigns, requests info, decides (insider-connected / external / dispute / process violation / false positive / inconclusive).
- 15. The export produces PDF + JSON manifest with hashes. The case record is appended to the evidence store.
- 16. Late-arriving events trigger re-evaluation; alert versions record every change.
- 17. The evaluation runner compares alerts against ground truth and computes metrics and ablations.

```
sequenceDiagram
    autonumber
    participant SIM as Simulator
    participant ING as Ingestion
    participant ST as Evidence + State Store
    participant DET as Pattern / Access / Integrity
    participant CON as Connection Engine
    participant CF as Counterfactual Engine
    participant TRI as Triage
    participant UI as Dashboard
    participant INV as Investigator
    SIM->>ING: events (actions, authorizations, state writes, MFA, transactions)
    ING->>ST: validated, ordered events + new versions
    ST->>DET: incremental updates
    DET->>CON: pattern hits, misuse signals, hollow passes
    CON->>CF: connected candidates + dependency ancestry
    CF->>CF: Remove replay (minimal disabling sets), Reach scan
    CF->>TRI: roles, coverage, exposure
    TRI->>UI: alert (level + reasons + evidence panel)
    INV->>UI: inspect, toggle Remove, view Reach
    INV->>UI: assign / decide
    UI->>ST: case record (hash-chained)
    UI->>INV: evidence export (PDF + JSON manifest)
```

```
stateDiagram-v2
    [*] --> NEW
    NEW --> TRIAGED
    TRIAGED --> ASSIGNED
    ASSIGNED --> INVESTIGATING
    INVESTIGATING --> PENDING_INFO
    PENDING_INFO --> INVESTIGATING
    INVESTIGATING --> DECIDED
    DECIDED --> CLOSED
    CLOSED --> [*]
```

14. Example System Execution

*Constructed illustrative scenario. All values are scenario parameters written for explanation. They are **not** measured results.*

Input events

Time (sim)	Event	Actor / source
------------	-------	----------------

D1 23:38	Login on terminal T-2-04 (Branch 2); attendance shows punch-out 19:02	Credential E-17
D1 23:40	Mobile change on dormant senior-citizen account A-4471	E-17
D1 23:41	Ticket for that change created	E-17
D1 23:41	"Mobile changed" SMS sent to the new number	SMS gateway
D1 23:44	Beneficiary B-903 added; OTP to new number; verified	Net banking
D2 10:05	Accounts A-2210 and A-2215 opened on T-2-04	E-17
D3 09:05	FD on A-4471 closed early; OTP to new number; verified	Net banking
D3 09:12	9L A-4471 B-903	Transfer
D3 09:19–11:30	B-903 A-2210 A-2215 back to A-4471 (partial)	Transfers

Internal representation

- mobile(A-4471) : v3 (customer, historic) **v4** (writer E-17 action at 23:40)
- Ticket created 1 minute after the change by the actor $g = X$ $\tau(v4) = 1$
- beneficiaries(A-4471) : v7 adds B-903. Its MFA consumed mobile v4 $\tau(v7) = 1$
- Transaction T^* consumed {status v2, limit v5, beneficiaries v7, mobile v4}

Processing and decisions

Step	Engine	Result
1	Pattern	Cycle B-903 A-2210 A-2215 A-4471, closes within the fast window; intermediates pass-through; accounts new
2	Explanation	No group code, mandate, recurrence, history or economic outflow unexplained
3	Integrity	MFA for beneficiary add, FD closure and transfer: PASS · HOLLOW (input mobile v4 tainted)
4	Access rights	E-17: contact-change permission , out of portfolio (P2), off-shift (P3), self-created ticket (P1), dormant-account targeting (P9)
5	Connection	STATE_DEPENDENCY (v4, v7 T^*); ONBOARDING (A-2210, A-2215 by E-17); INFRASTRUCTURE (T-2-04)
6	Remove	Candidates {mobile change, beneficiary add, FD closure}. Removing the mobile change OTPs go to v3 (real customer) beneficiary add fails cascade T^* fails NECESSARY . The "mobile changed" SMS to the new number CONCEALING .
7	Reach	Accounts with tainted channel + new beneficiary + dormant/senior + no artifact list with exposure
8	Confidence	Critical links corroborated by core banking + MFA gateway + SMS gateway HIGH
9	Triage	Rule 4 HIGH (insider-connected circular transfer)

Final output (alert card)

ALERT A-0193 · HIGH · Insider-connected circular transfer · Evidence: HIGH · Coverage: full
 PATTERN 4-hop loop; intermediates pass-through; accounts opened D2
 EXPLANATION group code mandate history economic outflow
 CONNECTIONS STATE_DEPENDENCY: mobile v4, beneficiary v7 credential E-17 (Grade X)
 ONBOARDING: A-2210, A-2215 E-17, terminal T-2-04
 ACCESS P1 P2 P3 P9 · attribution consistency: MEDIUM · 7 staff hold the same permission

CONTROLS MFA PASS HOLLOW (OTP to number set by E-17, no customer request)
 REMOVE mobile change: NECESSARY · beneficiary add: NECESSARY · SMS to new number: CONCEALING
 REACH accounts in the same pre-transfer state: listed with exposure
 STATEMENT Operational dependency under modelled controls. No finding of intent.

Variations

Variation	KHOJI's conclusion
Customer lost phone; V-CIP recovery (Grade A)	v4 untainted no Hollow INFO / no alert
Mobile not changed; OTP to the real customer, ignored	NEAR-MISS (control held)
E-17 on approved leave; VPN; new terminal	Same activity alert; credential-misuse indicators ; attribution LOW
Beneficiary change approved by E-22 in 4s, high pair lift	Collusion signal P5
Only email changed; phished OTP on the real mobile	External fraud (MEDIUM) ; the email change marked CONCEALING
MFA records missing for D3	DATA-GAP / INCONCLUSIVE , listing missing records
Treasury sweep loop with group code + mandate	INFO (explained)

15. Novelty / Innovation

***Principle:** Combining existing technologies is not novelty by itself. Each claim below states the existing approach, its limitation, our mechanism, and why the difference matters. All claims are limited to the public material we reviewed; proprietary systems may contain similar capabilities.*

Algorithmic

N1 — Minimal-disabling-set replay over an executable banking control model (Remove)

Element	Description
Existing approach	Detection-rule replay keeps history fixed and changes the rule (CyberSource, Lithic). Security provenance triage scores dependency graphs by historical frequency (NoDoze).
Limitation	Neither edits <i>recorded history</i> while holding <i>preventive business controls</i> fixed. Single-event but-for misclassifies redundant enablers.
Mechanism	Set-based replay with cascade, coverage bound κ and dual-order checking necessary / jointly necessary / contributory / concealing
Why it matters	Turns “happened nearby” into “the recorded path depended on this, under the bank’s own rules”, while stating its limits
Status	Application of an existing formal idea (counterfactual dependency) to a new domain with a specific operational semantics. Not a new theory.

N2 — Control-integrity taint (Hollow Pass)

Element	Description
---------	-------------

Existing approach	Controls evaluate possession (OTP). Cooldowns delay; e.g. one bank frames its 12-hour cooling period as a customer reporting window. Patents correlate user changes to records with later transactions (US10360399B2) and score changes to account data as triggering events (US11017464).
Limitation	Correlation does not state that a <i>control</i> passed on compromised input. Cooldowns do not verify.
Mechanism	Grade every state write; propagate taint into every control evaluation that reads it; report PASS · HOLLOW
Why it matters	Targets the recurring Indian insider pattern of rerouted OTP/alert channels
Status	New application of taint tracking to banking control inputs

Architectural

N3 — One replay function serving three questions (`replay(history_edit, control_config)` Remove, Reach, Repair)

- Existing: separate tools for backtesting, link analysis and investigation.
- Status: **engineering design choice, not research novelty**. It matters for build size and coherence.

Workflow

N4 — Evidence-graded investigation with first-class abstention

- Existing: SHAP-style feature importances are given to AML investigators.
- Limitation: they explain the model, not the event sequence or data gaps.
- Mechanism: expected-evidence contracts, weakest-link confidence, INCONCLUSIVE with named gaps.
- Status: **workflow/integration contribution**.

Application-specific

N5 — Reach: precondition-based exposure scan. Existing link analysis (DataWalk, Quantexa) expands by relationships. Reach expands by *state*. Status: **new application**.

N6 — Repair: preventive-control counterfactual with benign-friction measurement. Existing backtesting evaluates detection rules. Status: **new application; optional in the prototype**.

N7 — Access-rights misuse signals P1–P10. Commercial platforms already offer collusion and relationship discovery (NICE Actimize). Status: **integration, not novel**.

Research artefact

N8 — Open joint benchmark

Element	Description
Existing	SAML-D already includes 11 normal typologies alongside 17 suspicious ones (transactions only). CERT covers employees only and is static.
Contribution	Employee + access + authorization + state + money layers with paired legitimate twins, provenance ground truth, hidden primed accounts and abstention labels
Status	Research contribution (workshop-level) . Validity limited to synthetic data.

Not novel (we use but do not claim)

Transaction-pattern detection, graph analytics, anomaly detection, employee–transaction correlation, case management, hash chains, replay/backtesting in general, OTP/MFA, maker-checker, cooldowns, “digital twins” (already marketed by vendors such as Lucinity and Reform Technologies).

Patentability

Low. Relevant prior art includes insider-fraud detection (US8868728B2), event correlation around transactions (US10360399B2), account-takeover triggering events (US11017464) and real-time segregation-of-duties detection (US10257228). No patent claim is made.

16. Existing Solutions vs Proposed Solution

Capability	Rule-based transaction monitoring	Commercial fraud / employee-fraud / link-analysis platforms	Detection-rule replay / backtesting tools	Academic AML graph ML	KHOJI (proposed)
Core method	Threshold/typology rules	Rules + ML + graph + case management	Re-run rules on history	GNN / GBT on transaction graphs	Rules + baselines + typed dependencies + counterfactual replay
Main objective	Flag suspicious transactions	Detect fraud across channels incl. employees	Tune detection rules	Classify illicit transactions	Reconstruct <i>how</i> money moved, with evidence
Employee / access context	No	Yes (Actimize, Vyntra, DataWalk, Clari5)	No	No	Yes
Account-state versioning exposed to investigators	No	Not publicly documented	Point-in-time features	No	Yes
Control-integrity check (Hollow Pass)	No	Not publicly documented	No	No	Yes
Counterfactual over history	No	Not publicly documented	No (changes rules)	No	Yes (Remove)
Preventive-control what-if	No	Not publicly documented	Detection rules only	No	Optional (Repair)
Legitimate look-alike handling	Weak (high false positives)	Context and entity resolution	Measures impact of rule changes	Label-dependent	Explanation check + authorization grades + twins
Explainability	Rule text	Features, visuals, case tools	Rule-level	Low-medium	Evidence panel, roles, reasons
Uncertainty handling	None	Not publicly documented	N/A	Scores	INCONCLUSIVE + named gaps
Maturity / scale	Very high	Very high	High	Research	Prototype only
Main limitation	Noise	Closed; methods not public	Doesn't edit history	No insider layer	Synthetic validation only; control-model fidelity unproven

Proposed advantage	—	—	—	—	Open, measurable reconstruction of insider-enabled paths
--------------------	---	---	---	---	--

17. Implementation Strategy

Code is written within the 24-hour window per HackMatrix rules. Design documents and scenario specifications may be prepared beforehand.

Phase	What is implemented	Inputs	Outputs	Dependencies	Testing	Completion criteria
1 Data & simulator	Background process models, scenario library, imperfection injector, ground truth	Config, YAML	Event stream + labels	None	Seed determinism; scenario sanity checks	One attack + its twin visible end-to-end in raw events
2 Evidence & state	DuckDB log, hash chain, versions, roles/permissions/assignments	Events	Tables	Phase 1	Hash tamper test; as-of queries	Correct versions for all scenario write
3 Detection	Cycles, splitting, profile mismatch, explanation checker	Tables	Candidates	Phase 2	Unit tests per pattern + twin	All three patterns detected; twins explained
4 Integrity & access	Grades, taint, Hollow Pass, P1–P10, identity	Tables	Flags, signals	Phase 2	Grade/taint unit tests	Hollow flags correct on takeover scenario
5 Connections & counterfactual	Connection Engine, provenance, Remove, Reach; Repair gated	Candidates, Γ	Roles, exposure	Phases 3–4	Overdetermined + cascade test cases	Remove labels match ground truth on constructed cases
6 Confidence & triage	Contracts, weakest-link, decision table	All	Alerts	Phase 5	Data-gap scenarios	INCONCLUSIVE produced where expected
7 UI & cases	Graph, timeline, evidence and access panels, Remove toggle, case workflow, export	API	Dashboard, packs	Phase 6	Walkthrough	Every alert has an evidence panel; export verifies
8 Evaluation	Metrics, baselines, ablation	Alerts + ground truth	Scoreboard	Phase 6	Recompute on fixed seeds	Metrics reproducible
9 Demo hardening	Scripted replay, fallbacks	All	Demo	All	Rehearsal	Deterministic demo run

24-hour allocation (proposed)

Person	Hours 0–8	Hours 8–16	Hours 16–24
P1 (ML/infra lead)	Evidence store, versions, control model	Connection Engine, Hollow Pass, Remove	Reach, (Repair if on track), evaluation runner
P2	Simulator background activity	Attack/twin scenarios (blind to thresholds)	Held-out families, demo data
P3	Pattern engine + explanation checker	Grades, access-rights signals, collusion	Triage tuning on validation seeds only
P4	Dashboard shell, graph, timeline	Evidence panel, access-rights panel, Remove toggle	Case workflow, export, scoreboard, rehearsal

Checkpoints:

- **Hour 12:** all three PS patterns detected with evidence panels.
- **Hour 17:** connections + access-rights panel live.
- **Hour 18:** Repair go/no-go.
- **Hour 20:** feature freeze.

18. Data Flow

flowchart LR

```

SRC["Event sources<br>simulated CBS · MFA gateway · SMS gateway<br>HR · IAM · tickets"] --> VAL["Validate<br>sch"]
VAL --> LOG["Append-only<br>hash-chained log"]
VAL --> VER["State versions"]
VAL --> GAP["Gap log"]
LOG --> FEAT["Graph & feature builders"]
VER --> FEAT
FEAT --> DETS["Detectors<br>patterns · access · integrity"]
DETS --> LINK["Connections + provenance"]
LINK --> REPLAY["Replay engine<br>Remove · Reach · Repair"]
GAP --> CONF["Confidence"]
REPLAY --> CONF
CONF --> TRI["Triage"]
TRI --> ALERTS["Versioned alerts"]
ALERTS --> DASH["Dashboard"]
DASH --> CASES["Cases + decisions"]
CASES --> LOG
CASES --> EXPORT["Evidence pack<br>PDF + JSON + hashes"]
ALERTS --> METRICS["Evaluation runner"]
GT["Ground truth"] --> METRICS

```

Logging and analytics:

- Every alert version, investigator view/action and export is appended to the log.
- The evaluation runner reads alerts and ground truth only. It never feeds labels back into detectors (prevents leakage).

19. Feasibility

19.1 Technical Feasibility

High for the prototype. All components use standard Python and web tooling. The riskiest piece is replay correctness (cascade semantics), which is mitigated by building `replay()` first with unit tests on constructed cases.

19.2 Computational Feasibility

Prototype scale (proposed: 3 branches, 30 employees, 2,000 customers, 30 simulated days) fits on a laptop.

- Remove is bounded by $k \leq 8$ (≤ 256 replays per alert).
- Cycle search is bounded by L and W.

Requires Validation: actual per-alert latency.

19.3 Data Feasibility

Real joint data (employee actions + authorizations + state + money) is *not available* to the team. The prototype relies on synthetic data. SAML-D (transactions only) can sanity-check the transaction layer.

19.4 Operational Feasibility

In production, KHOJI would need:

- core-banking audit trails
- MFA/SMS gateway logs with destination versions
- authorization/ticket systems
- HR/IAM/attendance feeds
- a control model validated with the bank

Assumption: banks can export these. Not specified in the provided material for any specific bank.

19.5 Prototype Feasibility

The core contribution (Hollow Pass + Remove + connections + evaluation) is demonstrable within 24h if scope rules in §17 are followed. Repair is optional.

19.6 Scalability Feasibility

Production scale would require:

- streaming ingestion
- a persistent graph or partitioned in-memory graphs by account neighbourhood
- incremental replay caching
- role-based multi-user case management

These are outside prototype scope. **Not specified in the provided material:** production volumes and latency requirements.

20. Risks and Mitigation

Risk	Why it could occur	Impact	Likelihood	Mitigation	Fallback
Scope overrun	Many modules in 24h	Missing mandatory outcomes	High	P0/P1/P2 priorities; Repair gated at hour 18	Drop Repair, then Reach
Replay bugs	Cascade semantics subtle	Wrong necessity labels	Medium	Build <code>replay()</code> first; constructed test cases	Show single-event but-for with a caveat

				(overdetermined, cascade)	
Benchmark too easy	Twins differ only by a perfectly logged authorization field	Twin FPR trivially near zero; weak evidence	High	Inject realistic noise: legitimate cases with missing/late artifacts, Grade C/D legitimate work, mislabelled tickets	Report results with and without noise
Circular evaluation	Same team writes generator and detector	Inflated metrics	High	Blind scenario authoring; held-out families; randomised parameters; external SAML-D check	State limitation explicitly
Control-model fidelity	Real bank controls differ	Replay conclusions wrong in production	Medium (production)	Coverage κ ; INCONCLUSIVE when unmodelled	Frame as method demonstration
Over-claiming novelty	Pitch pressure	Loss of credibility	Medium	\$15 claim/no-claim list	—
False accusation perception	Employee names on alerts	Ethical/reputational	Medium	Credential-level language; no intent statements; contribution graph without blame	—
Hash chain weakness	Writer could recompute the chain	Tampering undetected	Medium	Anchor the head hash externally (export manifest, separate file)	Document limitation
Clock/ordering errors	Skew, delays	Wrong order wrong roles	Medium	Interval ordering; dual-order replay INCONCLUSIVE	—
Isolation Forest instability	Small synthetic populations	Noisy mismatch flags	Medium	Rule checks alongside; fixed seeds	Rules only
UI performance	Large graphs	Demo lag	Medium	Pre-computed layouts; scoped neighbourhood views	Static screenshots backup
Live demo failure	Integration issues	Poor judging impression	Medium	Scripted deterministic replay; offline mode	Recorded video
Jury comprehension	Counterfactuals are abstract	Innovation missed	Medium	Real-case hook; one toggle interaction	—

21. Failure Cases and Edge Cases

Scenario	Expected behaviour	Failure risk	Detection	Recovery / fallback
Missing MFA record	DATA-GAP with a named gap	Hollow Pass cannot be decided	Expected-evidence contract	INCONCLUSIVE; request logs

Authorization source unavailable	Grade U no HIGH	Wrongly treating as E	Source availability flag	DATA-GAP
Duplicate logs	Dedup by (source, seq)	Double counting	Idempotency keys	Content-hash fallback
Out-of-order / late events	Re-evaluate; versioned alert	Stale conclusions	Watermarks	Alert upgrade/downgrade trail
Clock skew changes order	Dual-order replay	Wrong roles	Interval overlap	INCONCLUSIVE if roles differ
More than k_max candidates	Top-k by depth/grade/rarity	Missed jointly necessary sets	Candidate count	PARTIAL label
Control not modelled	Coverage below k_min	False NECESSARY	Coverage check	INCONCLUSIVE naming the control
Redundant enablers	JOINTLY NECESSARY	Misread as irrelevant	Minimal disabling sets	—
Removal cascades	Downstream ops dropped	Incorrect replay	Cascade tests	—
Credential compromise	Attribution LOW; misuse indicators	Wrong person implicated	Leave/attendance/device checks	No-intent language
Customer denies despite clean MFA	INCONCLUSIVE on insider involvement	Wrong liability view	Channel integrity check	Route to dispute team
Legitimate cycle without mandate data	UNEXPLAINED-REVIEW, not HIGH	False positive	Explanation status	Reviewer decision
Fake-invoice circular trading between real firms	UNEXPLAINED-REVIEW ("bank data cannot verify trade")	Missed crime or wrongly cleared	Missing economic outflow	Escalate; needs GST data. In one GST case, 15 companies filed returns from the same IP addresses, and firms had inward e-way bills but no outward ones.
Profile edited to hide mismatch	PROFILE_EDIT connection	Mismatch suppressed	Versioned profile fields	—
MFA outage	Control not evaluated DATA-GAP (priority if tainted)	Missing hollow detection	Gateway health events	Priority review
Investigator marks alert false	Scoped, expiring suppression	Over-suppression	Suppression audit	Expiry
Two investigators edit one case	Last-write conflict	Lost updates	Version checks	Optimistic locking
Extremely large graph (future)	Scoped traversal	Latency	Timing logs	Neighbourhood limits

22. Security, Privacy and Reliability

Security

Area	Prototype	Production (proposed)
Authentication	Single demo login per role	Bank SSO
Authorization	Investigator vs supervisor roles	Need-to-know per case; four-eyes on exports
Input validation	Schema validation at ingestion	Plus source authentication
API security	Local only	TLS, rate limits
Data protection	Synthetic data	Encryption at rest/in transit; tokenised customer IDs
Abuse prevention	Audit log of views and actions	Plus anomaly monitoring of investigator access

Privacy

Aspect	Position
Data collected	Banking-system actions, authorizations, state changes, transactions, HR/attendance metadata
Sensitive data	Customer identity and financial data; employee attendance/leave
Minimisation	Only banking-system actions, not personal employee activity
Retention	Not specified in the provided material. Production would follow bank policy and applicable Indian law (including the DPDP Act, 2023).
Access control	Role-based, case-scoped
Prototype	Synthetic data only; no real PII

Reliability

Mechanism	Description
Error handling	Invalid events quarantined with reasons
Fallbacks	INCONCLUSIVE instead of forced verdicts; Repair/Reach optional
Logging	Every alert version and user action appended
Monitoring	Ingestion lag, gap counts, replay durations (prototype-level counters)
Recovery	Deterministic re-run from seeds and log
Graceful degradation	Missing modules degrade to fewer evidence rows, never to fabricated ones

23. Evaluation Strategy

23.1 Evaluation Questions

ID	Question
EQ1	Does KHOJI detect the three PS patterns in both pure and insider-connected variants?

EQ2	Does it keep false positives low on legitimate look-alikes (twins and background)?
EQ3	Are the money employee connections correct (type and credential)?
EQ4	Are Remove's dependency labels correct, including redundant and cascade cases?
EQ5	Does Hollow Pass / authorization grading reduce twin false positives compared with transaction-only and time-window baselines?
EQ6	Does Reach find hidden primed accounts before transfers?
EQ7	Does KHOJI abstain correctly when evidence is missing?
EQ8	Is every alert explainable with complete evidence?
EQ9	Is the system deterministic and fast enough for interactive investigation at prototype scale?

23.2 Metrics

Metric	What it measures	How it is calculated	Target / Baseline
Detection precision / recall / F1	Detection accuracy (PS wording)	Scenario-level TP/FP/FN per pattern and variant	To be established experimentally; compared with B1-B4
False-positive rate (twins)	Legitimate look-alike handling	Legitimate twins with HIGH/MEDIUM ÷ total twins	To be established experimentally
False-positive rate (all legitimate)	Overall noise	Legitimate scenarios alerting ÷ total legitimate scenarios	To be established experimentally
Alerts per 10k transactions	Operational load	Alerts ÷ transactions × 10,000	To be established experimentally
Connection accuracy	Correct links	Correct (type, credential) ÷ ground-truth connections	To be established experimentally
Privilege-signal precision	Misuse signal quality	Correct signals ÷ emitted signals	To be established experimentally
Remove label accuracy	Necessity classification	Correct roles ÷ candidates, split by simple / overdetermined / cascade	To be established experimentally
Provenance precision / recall	Evidence relevance	Cited true enablers ÷ cited; cited true enablers ÷ all true enablers	To be established experimentally
Hollow-flag precision / recall	Control-integrity detection	vs ground-truth tainted inputs	To be established experimentally
Reach exposure recall	Pre-loss exposure	Hidden primed accounts found before transfer ÷ hidden primed accounts	To be established experimentally
Pre-loss detection rate	Early warning	Attacks with WATCH/NEAR-MISS/HIGH before funds exit ÷ attacks	To be established experimentally
Abstention correctness	Honest uncertainty	INCONCLUSIVE on data-gap scenarios ÷ data-gap scenarios; wrongful-INCONCLUSIVE rate on complete data	To be established experimentally
Evidence completeness	Explainability	Alerts with ≥1 raw event per evidence dimension ÷ alerts	To be established experimentally

Detection latency (simulated)	Timeliness	Sim-time from first suspicious money movement to alert	To be established experimentally
Processing latency	Interactivity	Wall-clock per event batch; per Remove replay	To be established experimentally
Resource consumption	Feasibility	Peak memory, CPU time per run	To be established experimentally
Scalability	Growth behaviour	Throughput and latency at proposed scale factors (1×, 5×, 10× simulator size)	To be established experimentally
Reproducibility	Reliability	Identical outputs across repeated seeded runs	Expected identical; verify
Repair friction (optional)	Cost of controls	Legitimate ops delayed/blocked per 10,000	To be established experimentally
Reviewer effort (optional)	User experience	Manual sources needed / time to answer a fixed question set	To be established experimentally (small informal test)

24. Baseline Comparison

Baseline	What it does	Why appropriate	Metrics compared	Improvement means
B0 Naive time-window linking	Links any employee action on an account within Δ before a suspicious transaction	The obvious “correlation” approach many teams would use	Connection accuracy, provenance precision, twin FPR	Higher precision at equal or better recall
B1 Transaction-only rules	Standard cycles / splitting / mismatch with thresholds, no explanation check	Represents traditional transaction monitoring	Detection accuracy, FPR	Lower FPR at equal or better recall
B2 B1 + explanation check	Business-context-aware monitoring	Strong baseline resembling context-aware commercial monitoring	Twin FPR, insider recall	Recall on insider-connected cases without FPR increase
B3 B2 + unlinked employee anomaly	Flags unusual employees separately (status-quo separate teams)	Mirrors the PS’s “separate teams” situation	Connection accuracy, time-to-link	Correct connections that B3 cannot produce
B4 Supervised GBT on transaction features	Gradient-boosted classifier, similar in spirit to MuleHunter’s supervised ensembles	Standard ML baseline	Detection accuracy under leave-one-family-out	Better generalisation to held-out families (Requires Validation)
Ablations of KHOJI	+ versioned dependency + authorization/Hollow Pass + Remove + evidence confidence	Shows each component’s contribution	All headline metrics	Each addition improves its target metric

25. Experimental Setup and Success Criteria

25.1 Dataset

Item	Detail
Source	KHOJI synthetic bank simulator (to be built)
Structure	Events per §4.2 + ground-truth YAML (scenario type, label, twin link, outcome, principals, event roles, connection types, misuse signals, expected level, expected INCONCLUSIVE)
Size	Proposed: 3 branches, 30 employees, 2,000 customers, 30 simulated days. Number of scenario instances: not specified.
Scenario families	Circular transfers, splitting, profile mismatch (each pure / insider-connected / twin); takeover; collusion; credential compromise; near-miss; data-gap; hidden primed accounts
Imperfections	Missing records, duplicates, delays, skew; noisy legitimate authorization (to avoid a trivially easy benchmark)
Split	Seeds split into tuning and test sets; ≥ 2 scenario families held out and written after detector freeze
External check	SAML-D (9.5M transactions, $\sim 0.1\%$ suspicious) for the transaction layer only

25.2 Test Environment

Not specified in the provided material. Planned: Python, DuckDB, NetworkX, scikit-learn, FastAPI, React on team laptops. Hardware specs to be recorded at run time.

25.3 Test Cases

Type	Examples
Normal	Background operations, payroll, sweeps, refunds, recoveries
Attack	All families in §25.1
Edge	Redundant enablers, cascades, ordering ambiguity, missing MFA, Grade U sources, profile-edit hiding
Stress	Scale factors 1 $\times$, 5 $\times$, 10 $\times$ (proposed)
Adversarial	Blind-authored scenarios; attacker waits past cooldown; split actions across employees

Number of test cases: not specified. Open Technical Decision: seeds per family.

25.4 Evaluation Procedure

1. Generate data for tuning seeds; tune thresholds **only** on tuning seeds.
2. Freeze detectors.
3. Author held-out families; generate test seeds.
4. Run baselines B0–B4 and KHOJI ablations on identical test data.
5. Compute metrics (§23.2), per pattern and variant.
6. Repeat with and without legitimate-authorization noise.
7. Run SAML-D sanity check for transaction-layer detectors.
8. Record runtime and resource metrics.
9. Report all results with seed counts; no cherry-picking.

25.5 Success Criteria

A successful prototype demonstrates:

1. All five PS expected outcomes working end-to-end in a live, deterministic demo.
2. Detection of all three PS-named patterns in pure and insider-connected variants, with legitimate twins handled.
3. Measurably lower false-positive rate than B1 on legitimate scenarios without lower recall on insider-connected attacks (relative improvement; **no numeric target set**).
4. Remove labels matching ground truth on constructed simple, overdetermined and cascade cases.
5. Correct INCONCLUSIVE outputs on data-gap scenarios.
6. Every alert carrying a complete evidence panel; every export passing hash verification.
7. Ablation showing that authorization grading/Hollow Pass contributes to reduced twin false positives (**Requires Validation**).

26. Critical Review of the Proposed Design

#	Finding	Type	Recommendation
1	Terminology evolved during design (“causal chain” “enabling-event provenance” “operational dependency”)	Inconsistency	Use “ operational dependency under modelled controls ” everywhere; never “causal”
2	Earlier demo scripts used figures like “3 genuine customers per 10k” and “ 1.2 Cr exposed”	Unsupported numbers	Treat as placeholders; replace with measured values or remove
3	Remove and Repair are exact <i>by construction</i> inside the simulator	Evaluation limitation	Present their evaluation as <i>implementation correctness</i> , not real-world validity
4	Twin benchmark may be trivially easy if authorization is always cleanly logged	Validity risk	Inject realistic noise into legitimate authorization; report both variants
5	Grade E conflated “no artifact” with “no data”	Design gap	Added Grade U (source unavailable) DATA-GAP
6	Coverage κ needs a denominator (“all applicable controls”) that is unknown in real banks	Open issue	Keep κ in simulation; in production, derive from a bank-validated control inventory
7	Hash chain alone doesn’t stop an attacker with write access from recomputing it	Security gap	Anchor head hashes externally (export manifest, separate store)
8	Novelty relative to proprietary vendors cannot be verified	Claim limitation	Phrase as “not found in reviewed public material”
9	Structuring thresholds and Isolation Forest parameters are unspecified	Missing detail	Listed as Open Technical Decisions
10	Production assumes consumed-state logging per transaction/control	Assumption	State explicitly; required integration point
11	24h scope is large	Implementation risk	Enforce priorities and hour-18 Repair gate
12	Isolation Forest on small synthetic populations may be unstable	Technical risk	Pair with rule checks; fixed seeds
13	Bank-data-only analysis cannot verify fake-invoice trade	Inherent limit	Output UNEXPLAINED-REVIEW, never “legitimate”

27. Assumptions, Open Decisions and Validation Register

Assumptions

ID	Assumption
A1	Production banks can export audit trails, MFA/SMS logs with destinations, authorization artifacts and HR/IAM data
A2	Transactions and control evaluations can record consumed state versions
A3	Bank controls can be expressed as predicates with acceptable fidelity
A4	Synthetic scenarios reflect key real patterns (grounded in public Indian cases)
A5	Investigators prefer evidence chains and abstention over single scores (consistent with the PS wording)

Open Technical Decisions

ID	Decision
D1	Cycle windows W and max length L (proposed 72h/30d, $L \leq 6$)
D2	Splitting threshold set T , band δ , $n_{\min}$
D3	Isolation Forest features and contamination parameter
D4	Grade rules for partial artifacts; taint sanitization rules
D5	$\kappa_{\min}$ and control inventory definition
D6	$k_{\max}$ beyond 8 (partial search strategy)
D7	Per-source clock-skew bounds
D8	Seeds per scenario family; number of test cases
D9	UI timeline and PDF libraries
D10	Lookback Λ for provenance

Requires Validation

ID	Claim
V1	Authorization grading + Hollow Pass reduce twin false positives vs baselines
V2	Remove produces correct labels on redundant and cascade cases
V3	Reach finds primed accounts before transfers
V4	Remove latency is interactive at prototype scale
V5	Results hold with legitimate-authorization noise
V6	Transaction-layer detectors behave sensibly on SAML-D
V7	Reviewer effort is reduced (optional informal test)

28. Demonstration Plan (≈ 4 minutes)

Time	Beat	PS outcome shown
0:00	Real-case hook: contact details changed, FDs broken	Problem
0:20	Live money-flow graph + activity timeline	Outcome 1

0:40	Circular transfer connected to E-17 (onboarding + state dependency); treasury-sweep twin silent	Pattern + connection + legitimate scenario
1:10	Splitting after an employee limit raise; payroll twin silent	Pattern + connection
1:30	Profile mismatch hidden by an employee's income-band edit	Pattern + connection
1:50	Alert: level + reasons + evidence panel + MFA PASS HOLLOW	Outcomes 2, 5
2:15	Access-rights panel: valid permission misused; "who else could have done this"	Access rights / privilege misuse
2:35	Remove toggle path fails NECESSARY	Evidence-backed connection
2:55	Reach list (+ Repair table if built)	Differentiator
3:15	Assign decide export (hash verified)	Outcome 3
3:35	Scoreboard: detection accuracy + FPR per pattern; ablation; one honest blind spot	Outcome 4

29. Problem-Statement Traceability Matrix

PS element	KHOJI coverage	Section
Separate teams hide connections	Unified timeline + Connection Engine	4, 11
Employees, access rights, customers, transactions	Data model + Access-Rights module	4.2, 8
Insider privilege misuse	P1-P10, grades, Hollow Pass	11, 12
Circular transfers	Algorithm 2 + explanation + connections	11.3
Transaction splitting	Algorithm 3	11.3
Profile mismatches	Isolation Forest + rules + PROFILE_EDIT link	12
Money-flow graph + activity timeline	Dashboard	8.4
Explainable risk levels, not a single score	Algorithm 9 decision table	11.3
Case assignment + evidence export	Case workflow + hashed export	13
Tested on suspicious + legitimate for accuracy and FPR	Scenario library + evaluation	23-25
Mandatory evidence panel on every alert	FR17	7.1

30. Future Scope

- Integration with real core-banking, MFA/SMS gateway, ticketing and HR/IAM feeds
- Bank-validated control models and coverage inventories
- Streaming, persistent-graph production architecture
- Cross-bank exposure sharing (privacy-preserving)
- GST/goods-movement data to verify trade in circular patterns
- Learned triage ranking using real investigator decisions
- Formal user studies with investigators
- Multi-control Repair search with cost optimisation

31. Complete System Summary

What problem are we solving?

Separated monitoring hides how insider privilege misuse enables financial crime. Controls often pass because their inputs were compromised.

Why is it worth solving?

Large, recurring losses; regulatory staff-accountability and liability burdens on banks; alert noise; late discovery.

What are we proposing?

KHOJI, an investigation platform that reconstructs how suspicious money moved, which controls passed for the wrong reason, and which employee actions the movement depended on, with honest uncertainty.

What exactly are we building?

- synthetic bank + ground truth
- hash-chained evidence store with versioned state
- pattern, explanation, access-rights, integrity, connection and counterfactual engines
- explainable triage
- investigator dashboard with case management and export
- evaluation runner

How does it work?

Events versions pattern detection explanation check authorization grades and taint privilege signals typed connections Remove/Reach replay evidence confidence decision-table level evidence panel case export.

What is the core algorithmic idea?

Minimal-disabling-set replay over an executable control model (Remove), plus taint propagation into control inputs (Hollow Pass).

What makes it different?

It edits *history* under fixed *preventive controls* instead of changing detection rules. It flags *hollow* control passes. It is evaluated on an open benchmark with paired legitimate twins and abstention labels. Most other components are known techniques, integrated.

How will we prove it works?

Detection accuracy and false-positive rate per pattern on suspicious and legitimate scenarios, connection and Remove accuracy, Reach recall and abstention correctness. All are compared with baselines B0–B4 and ablations, using blind-authored and held-out scenarios.

What are its major risks?

Scope, replay correctness, an overly easy synthetic benchmark, evaluation circularity, control-model fidelity in production, and over-claiming.

What does a successful prototype demonstrate?

All five PS outcomes live. The three named patterns detected and connected. Lower false positives than transaction-only monitoring without losing insider recall. Correct Remove labels. Correct abstention. Verifiable evidence exports.

32. One-Page Technical Snapshot

Category	Summary
Problem	Separated monitoring hides links between insider privilege misuse and financial crime; controls pass on compromised inputs
Users / Stakeholders	Investigators, AML analysts, vigilance/compliance, customers, honest employees, auditors, law enforcement
Existing gap	Public material doesn't show open, measurable reconstruction of control integrity and operational dependency

Proposed solution	KHOJI investigation platform with evidence-backed, explainable alerts
Core technical idea	Versioned state + executable control model Hollow Pass + Remove replay
Architecture	Simulator ingestion hash-chained store + versions detection/access/integrity connections counterfactual confidence triage dashboard/cases evaluation
Main algorithms	Time-respecting cycles; sliding-window splitting; Isolation Forest; smoothed rarity; authorization grading; taint propagation; typed dependency traversal; minimal-disabling-set replay; precondition matching; pair lift; weakest-link confidence; decision-table triage
Technology stack	Python, DuckDB, NetworkX, scikit-learn, FastAPI/WebSocket, React + Cytoscape.js, SHA-256
Input	Employee actions, authorizations, state writes, approvals, MFA/notifications, control evaluations, transactions, HR/IAM
Output	Levelled alerts with reasons, evidence panels, contribution graphs, Remove/Reach results, cases, hashed exports
Novelty	Hollow Pass (taint into control inputs); set-based replay over banking controls; open joint benchmark with twins. Other parts are integration.
Baseline	B0 time-window linking; B1 transaction-only rules; B2 + explanation; B3 + unlinked employee anomaly; B4 supervised GBT; ablations
Evaluation metrics	Detection precision/recall/F1 and FPR per pattern; twin FPR; connection, Remove, provenance, Hollow accuracy; Reach recall; abstention; evidence completeness; latency
Major risks	Scope, replay correctness, easy benchmark, circularity, control-model fidelity, over-claiming
Success criteria	All PS outcomes live; three patterns connected; FPR below B1 without recall loss; correct Remove labels and abstention; verified exports
Future scope	Real integrations, validated control models, streaming scale, cross-bank sharing, GST data, learned triage, user studies

33. References

1. HackMatrix 5.0 Problem Statement Book, FIN-04 (provided PDF)
2. [Free Press Journal – Mumbai bank employees case](#)
3. [Tribune – ICICI relationship manager case](#)
4. [Business Standard – Anatomy of an insider bank fraud](#)
5. [Tribune – Gurugram bank employee arrested](#)
6. [Wikipedia – Haryana Government accounts fraud](#)
7. [Business Standard – RBI FY25 fraud data](#)
8. [Vajiram & Ravi – FY25 fraud composition](#)
9. [The420 – MuleHunter and I4C data](#)
10. [RBIH – MuleHunter.AI docs](#)
11. [PIB – MuleHunter deployment](#)
12. [ELP – RBI FRM Master Directions 2024](#)
13. [Ahlawat Associates – FRM directions](#)
14. [RBI – Limiting Liability of Customers](#)
15. [RBI – Draft circular, burden of proof](#)
16. [RBI/2025-26/52 – Inoperative accounts amendment](#)
17. [DataVisor – AML false positives](#)
18. [Clari5 – EFM product suite](#)

19. [Clari5 – Enterprise Fraud Management](#)
20. [NICE Actimize – Employee Fraud](#)
21. [NICE Actimize – Internal Threats](#)
22. [Vyntra – Internal fraud solutions](#)
23. [DataWalk – Internal fraud rings](#)
24. [Quantexa – AML solutions](#)
25. [BankInfoSecurity – CFCFRMS](#)
26. [Outlook Money – CFCFRMS savings](#)
27. [Digital Transactions – CyberSource Decision Manager Replay](#)
28. [Lithic – Backtesting](#)
29. [Flagright – Rule simulations](#)
30. [Lucinity – Digital twins](#)
31. [AML Intelligence – Reform Technologies](#)
32. [DBS – Cooling period](#)
33. [MoneySuperMarket Business Banking – Cooling-off](#)
34. [EastWest Bank – Transaction pause period](#)
35. [AMLworld \(alphaXiv\)](#)
36. [Graph Feature Preprocessor \(ACM\)](#)
37. [SAML-D \(GitHub\)](#)
38. [SAML-D statistics \(arXiv\)](#)
39. [CERT r4.2 description \(arXiv\)](#)
40. [OrgForge-IT on CERT limitations \(arXiv\)](#)
41. [NoDoze \(UIUC\)](#)
42. [Explainable AI in the financial sector \(arXiv\)](#)
43. [Process mining for internal control \(Accounting Horizons\)](#)
44. [US10360399B2](#)
45. [US8868728B2](#)
46. [US11017464](#)
47. [US10257228](#)
48. [South First – GST fake invoice case](#)